

Compte rendu de réunion Prototype INTRANET/EXTRANET

Notes de réunion – procédure à suivre pour le développement du prototype pour le projet INTRANET/EXTRANET.

Scope du projet

L'objectif est de créer un prototype du serveur qui va héberger les sites. Pour ça, il faut reprendre les arborescences de fichiers qui simulent l'arborescence des sources sur le serveur. Pour l'instant le développement n'a pas été fait, ça viendra plus tard. Pas besoin non plus de mettre en place le DNS.

1. Le serveur

- Préparation d'une machine virtuelle, capacité minimale 1 CPU, 1 024 ou 2 048 Mo de mémoire, 10 Go d'espace disque suffiront.
- Deux pattes réseaux :
 - une sur le 192.168.10.0/24 pour l'interne ;
 - une pour simuler l'externe en 150.10.0.0/16, par exemple.
- Installation d'une distribution Debian ou Ubuntu, mais en version minimale, pas d'environnement de bureau. On est ici sur un projet serveur.

2. Le service web

- Installation du serveur HTTPD d'Apache. À faire avec les packages de la distribution, inutile de compiler la dernière version.
- Création de deux virtual hosts :
 - extranet.valserac.com ;
 - intranet.valserac.com.

- Les deux vhosts doivent référencer deux arborescences de sources différentes. Recommandation : créer deux répertoires dans le /var/www (extranet.valserac.com et admin.valserac.com, par exemple).
- Le vhost extranet doit être accessible sur la patte réseau publique, le vhost intranet uniquement sur la patte privée.
- Changement du port d'écoute pour le vhost intranet en 5501 pour HTTP et 5502 pour le HTTPS, par exemple.
- Génération d'un certificat auto-signé wildcard pour les deux vhosts. Pour ça, il faut utiliser les données de l'entreprise et l'adresse mail admin (FR, ILE DE FRANCE, PARIS, CONSULAT, DIRECTION INFRASTRUCTURE ET LOGISTIQUE et admin@valseracom).
- Mise en place d'une redirection forcée des requêtes entrantes HTTP vers HTTPS pour les deux vhosts.
- Attention à créer deux fichiers de traces d'accès, un pour chaque vhost. Il est possible de garder le même fichier de trace pour les erreurs.
- Configurer les droits d'accès sur les répertoires sources du service HTTPD, il faut qu'ils soient sécurisés au maximum.
- Il faut cependant prévoir les droits d'écriture pour le vhost extranet dans le répertoire PDF, car les utilisateurs vont pouvoir charger des fichiers directement depuis le site.

→ **Facultatif : Tester cette partie 2 également avec NGINX.**

3. Le service FTP

- L'idée ici est de rendre accessibles les répertoires des sources des sites aux personnes qui en ont besoin.
- Les futurs développeurs vont avoir besoin d'accéder aux répertoires des codes sources des deux vhosts.
- Les graphistes doivent uniquement accéder aux répertoires des images des deux vhosts.
- Il faut bien évidemment refuser les connexions anonymes.
- Recommandation : créer des groupes Linux pour gérer ces droits et inventer deux comptes nominatifs de test : un pour un développeur et un pour un graphiste.

- Mise en place d'un cloisonnement via un chroot ou un jail sur ce service, pour bien le sécuriser.
- Le service FTP doit être uniquement accessible sur la patte privée.

4. Le filtrage

Un filtrage IP avec netfilter doit être appliqué sur le serveur en laissant passer le minimum de protocoles nécessaires sur les deux pattes réseau (il est possible de garder le flux SSH sur la patte interne pour l'administration du serveur).

5. La prévention sur la sécurité

5.1 / Modules Apache

Il faut mettre en place les mesures préventives suivantes en termes de sécurité :

- Utiliser le module `mod_evasive` qui permet de détecter et bloquer les modèles de trafic suspects caractéristiques des attaques par déni de service (DDoS) ou des connexions lentes. Ce module analysera le trafic HTTP entrant et prendra des mesures automatiques contre les clients présentant un comportement abusif.

5.2 / Mise en place de CrowdSec

Installer et configurer CrowdSec pour protéger l'extranet. CrowdSec est une solution moderne de détection et prévention d'intrusion qui offre plusieurs avantages. Pour ce projet il faut mettre en place :

1. **Surveillance des logs** : Configurer CrowdSec pour analyser les logs d'Apache (`access.log` et `error.log`) de l'extranet afin de détecter les comportements malveillants.
2. **Installation d'un bouncer** : Mettre en place un bouncer Apache qui servira d'agent d'application pour CrowdSec. Ce bouncer interceptera les requêtes et les bloquera si elles proviennent d'adresses IP identifiées comme malveillantes.

3. **Intégration avec Apache** : Configurer le VirtualHost de l'extranet pour utiliser les règles de protection fournies par le bouncer CrowdSec.